Synthèse complète – Sécurité de l'information, Cours 1 (p. 1 à 14)

(C. Batbedat, UE IERS, M2 VMI. Le poly marque « fin cours 1 » en p. 14, donc cette synthèse couvre les pages 1 à 14.)

Plan du cours 1 : 1. Définitions → 2. Motivations des attaquants → 3. Cibles → 4. Méthodes d'attaque → 5. Résumé

---

1. Les définitions (★★ base du vocabulaire)

Les termes généraux

Terme	Définition	À retenir
Cybersécurité	Ensemble des moyens **organisationnels, humains, techniques, juridiques**… mis en œuvre pour **garantir, conserver et rétablir** la sécurité d'un système d'information	Ce n'est **pas seulement technique**. Trois verbes : garantir, conserver, rétablir
Cybercriminalité	Toutes les **infractions pénales** qui peuvent se commettre **sur ou au moyen** d'un système informatique, généralement connecté à un réseau	3 catégories (voir ci-dessous)
Cyberterrorisme	*(définition controversée)* Activités perturbatrices **préméditées** contre des ordinateurs ou réseaux, pour causer un **préjudice ou un trouble sociétal** (social, idéologique, religieux, politique) afin d'**intimider**	Mots-clés : **préméditation, trouble sociétal, intimidation**
Cyberattaque	Acte **malveillant** envers un dispositif informatique **via un réseau**	

Les 3 catégories de cybercriminalité (★ très classique)

Catégorie	Principe	Exemples
Infractions spécifiques	L'informatique est la **cible** : elles n'existent pas sans informatique	Atteinte aux STAD, atteinte aux données sensibles, infractions aux cartes bancaires, chiffrements non autorisés, interceptions
Infractions liées	Des infractions classiques **commises via** les réseaux	Pédopornographie, atteinte aux personnes privées, incitation à la haine raciale ou au terrorisme
Infractions facilitées	L'informatique sert d'**outil facilitateur**	Escroqueries, blanchiment d'argent, contrefaçon, atteinte à la propriété intellectuelle

STAD = Système de Traitement Automatisé de Données. C'est le terme juridique français pour désigner un système informatique.

Les acteurs : hacker, white hat, black hat

Terme	Définition
Hacker (sens général)	Terme **générique, pas forcément informatique** : une personne passionnée par la compréhension du **fonctionnement intime** de quelque chose. Ce n'est **pas péjoratif**
Hacker informatique	Spécialiste des systèmes et réseaux, maîtrisant la **sécurité informatique ET les moyens de la déjouer**
White hat	Utilise son savoir-faire **dans un cadre légal** : chercheurs, responsables sécurité
Black hat	Utilise son savoir-faire **hors la loi** : pirates

→ **La compétence est la même, c'est le cadre légal qui fait la différence.**

La cryptologie (★★ piège classique d'examen)

Cryptologie = « science du secret ». Elle englobe :

- la **cryptographie** : l'écriture secrète (fabriquer du secret) ;
- la **cryptanalyse** : l'analyse de l'écriture secrète (casser le secret).

Terme	Clé connue ?	Sens
Chiffrement	Oui	Rendre une information **incompréhensible** pour qui ne possède pas la clé
Déchiffrement	Oui, **clé connue**	Inverse du chiffrement : rendre l'information compréhensible **avec la clé**
Décryptage	**Non**	Rendre l'information compréhensible **sans connaître la clé** : on trouve la clé, puis on déchiffre. En anglais, on dit « *casser le code* »
❌ **Cryptage**	—	**Mot à bannir.** Il signifierait « chiffrer sans connaître la clé », ce qui n'a **aucun sens**. C'est un anglicisme de *encryption*, qui veut dire **chiffrement**. Il vient de « chaîne cryptée » (Canal+). L'Académie française le rejette. **Ne jamais l'utiliser.**

Moyen mnémotechnique :

- **dé-CHIFF-rement** : j'ai le **chiffre** (la clé), c'est l'usage légitime ;
- **dé-CRYPT-age** : je **casse** la « crypte » sans clé, c'est une attaque ou de la cryptanalyse.

Termes d'attaque et d'accès

Terme	Définition	Sens du flux
Intrusion	**Entrer** (et généralement **se maintenir**) dans un système	Attaquant → système
Injection	**Importer** des informations (données, code) **dans** un système	Vers l'intérieur ⬇️
Exfiltration	**Retirer** des informations d'un système : données, mots de passe, fichiers confidentiels	Vers l'extérieur ⬆️
Identification	Établir l'identité : **« Qui êtes-vous ? »**	Déclaratif (ex. le login)
Authentification	Être **certain** de l'identité : **« Êtes-vous vraiment cette personne ? »**	Preuve (ex. mot de passe, 2FA)

→ Piège : **l'identification déclare, l'authentification prouve.** On s'identifie avec un login, on s'authentifie avec un mot de passe.

---

2. Les motivations des attaquants (★ « pourquoi attaque-t-on ? »)

Il y a **4 grandes motivations**.

① **Le gain financier (la motivation n°1)**

a) La fraude

- Définition : **détourner un usage légitime** ou **exploiter des défauts** pour gagner de l'argent.
- Les défauts exploités sont :
  - des **procédures** (enrôlement, vérification d'identité) ;
  - des **défauts de protection simples à exploiter**.
- Point clé : **le fraudeur n'a pas besoin d'une grande expertise technique.**

📊 **Observatoire de la sécurité des moyens de paiement (Banque de France, rapport 2025 publié le 9 septembre 2026)**

- **Total : 1,241 milliard d'€** de fraude, pour **7,5 millions de transactions frauduleuses**.

Moyen de paiement	Part en valeur	Part en volume
Virement	**39,1 %** 🥇	4,0 %
Carte	34,9 %	**91,5 %** 🥇
Chèque	18,5 %	2,2 %

Retrait DAB	3,4 %	1,4 %
Prélèvement	2,7 %	0,8 %
Effet de commerce	1,6 %	—

→ **À comprendre :**

- la **carte** représente l'essentiel des **fraudes en nombre** : beaucoup de petites fraudes ;
- le **virement** représente l'essentiel **en montant** : peu de fraudes, mais très coûteuses (fraude au président, faux RIB…).

Taux de fraude en valeur (2024 → 2025) :

Moyen	**2024 → 2025**
Chèque	0,0694 % → 0,0692 % (**le plus élevé**)
Carte	0,0531 % → 0,0472 %
Effet de commerce	0,0089 % → 0,0097 %
Virement	0,0011 % → 0,0015 %
Prélèvement	0,0014 %
Monnaie électronique	0,0078 % → 0,0005 %

b) La revente d'informations volées

- Via des **malwares** (virus, vers…) et des **keyloggers** (enregistreurs de frappe).
- **Vol de données de cartes bancaires.**
- **Exploitation du NFC** (paiement sans contact).
- Illustrations : fuites chez Avis, Boulanger, Cultura (1,5 million de clients), France Travail, SFR (IBAN, adresses, téléphones).

c) Le chantage

- **Cryptolockers**, ou rançongiciels : les données sont chiffrées puis une rançon est exigée.
- **Chantage à la webcam** (souvent du bluff, avec de prétendus « pirates »).
- **Leak d'informations** : menace de publier des données.

d) Les escroqueries

- Fausses ventes
- Appels surtaxés
- **Phishing** (hameçonnage)
- Arnaque « à la nigériane »
- Défauts dans les procédures

② **L'hacktivisme**

- Utiliser des outils de hack pour **défendre une idéologie**.
- Groupes les plus connus : **Anonymous**, **Occupy**.
- Moyens :
    - **déni de service** (DDoS) ;
    - **défacement** de sites web (modification de la page d'accueil) ;
    - **vol d'informations** ou *security leak*.
- Cibles : surtout des **entreprises et des États**, parfois des **personnalités publiques**.

③ **L'espionnage**

⚠️ Il est **très difficile d'avoir des statistiques fiables**, puisque le but est justement de **ne pas être repéré**.

Type	Objectifs
Industriel	Remporter des marchés ouverts, connaître la stratégie d'un concurrent, réduire la portée d'une annonce concurrente
Étatique	Voler des secrets militaires, manipulations politiques, influence stratégique (économique et industrielle). Ex. : Snowden, Belgacom, écoutes Merkel/Obama, Russie, Chine (« Crimson Palace »)
Particuliers	Surveiller un voisin, un(e) conjoint(e), des journalistes, un salarié

④ **L'acquisition de ressources d'attaque**

- L'attaquant ne cherche **pas ce que contient la cible**, mais son **potentiel offensif** :
    - **gros serveurs** (puissance) ;
    - **anonymisation** (servir de relais) ;
    - **gros débit** (bande passante).
- Ces attaques sont **discrètes**. Le but est de **contrôler un ensemble d'équipements**, par exemple un **botnet**, pour **revendre ces services dans l'underground**.

    💡 Conséquence : **personne n'est « trop petit » pour être attaqué.** Même un serveur sans données intéressantes a de la valeur comme ressource.

📊 **Statistiques des motivations (Hackmageddon, H1 2026 : 1127 motivations)**

Motivation	Nombre	Part
Cyber Crime	774	**68,7 %**
Cyber Espionage	220	**19,5 %**
Hacktivism	33	2,9 %
Cyber Warfare	31	2,8 %
Unknown	69	6,1 %

→ **Près de 7 attaques sur 10 sont motivées par l'argent.** L'espionnage arrive en 2e position.

À propos de Hackmageddon :

- base **open-source** créée par **Paolo Passeri** en **2011** ;
- publiée **toutes les deux semaines** ;
- chaque incident est **recherché, classé et vérifié manuellement** ;
- la classification est cohérente dans le temps : secteur ISIC, pays, motivation, tactique **MITRE ATT&CK** ;
- les revendications non vérifiées et les doublons sont exclus.

---

3. Les cibles (★ « qui est attaqué ? »)

① **Les États**

- Ils font de l'**espionnage** et de la **cyberguerre** pour leur sécurité intérieure ou extérieure, ou pour **gagner des marchés internationaux**.
- Enjeux : **politiques, militaires, économiques**.
- Leur cible est souvent **d'autres États**, mais elle peut être **intérieure** : c'est ce qu'ont montré les révélations de **Snowden**.

Exemples historiques à connaître :

Année	Événement
2008	**Operation Buckshot Yankee** contre les réseaux militaires américains
2010	**Stuxnet** ravage les systèmes **SCADA** (supervision industrielle Siemens : oléoducs, plateformes pétrolières, centrales électriques et nucléaires)
2011	Le site de l'**Élysée** est piraté (défacement humoristique du président)
2013	Un virus sophistiqué attaque **Belgacom** (opérateur belge)

> **SCADA** = systèmes de supervision et de contrôle industriels. **Stuxnet** est la première cyberarme connue capable de provoquer des **dégâts physiques**.

② **L'industrie**

L'industrie est **globalement insuffisamment protégée** alors qu'elle attire fortement les pirates. C'est donc une **cible de choix**.

📊 **Baromètre CESIN / OpinionWay, vague 11 (janvier 2026)**

- **40 % des entreprises ont subi au moins une cyberattaque en 2025.**
- **3,3 types d'attaques en moyenne** chez les victimes (4,0 à la vague précédente ; 3,9 dans les grandes entreprises).

Vecteurs d'attaque (★ le top 5 est à connaître) :

Rang	Vecteur	%

1	**Phishing, spear-phishing ou smishing**	**55 %**
2	**Exploitation d'une faille**	**41 %**
3	**Attaque indirecte via un tiers** (supply chain)	**35 %** (grandes entreprises : 43 %)
4	Fuite de données due à une erreur humaine ou de configuration	27 % (GE : 36 %)
5	Arnaque au président classique	26 % (30 % auparavant)
	Déni de service via un botnet (DDoS)	21 %
	Noms de domaine illégitimes / détournement de marque	17 % (27 % auparavant)
	Activation d'un composant malveillant	16 %
	Exfiltration ou sabotage par une personne ayant un accès légitime	14 %
	Perte ou vol de matériel	13 %
	Autre ingénierie sociale	12 %
	Application corrompue	12 %
	Outils non approuvés (**shadow IT**)	12 %
	Contournement de la double authentification (2FA)	11 %
	Arnaque par deepfake	5 % (GE : 9 %)
	Matériel malveillant (clé USB…)	4 %
	IA utilisée pour extraire des données	3 %
	Faille sur un système industriel	3 %
	Intrusion physique	1 %

Conséquences techniques :

Conséquence	%
Vol de données	**52 %**
Déni de service	28 %
Exposition de données	27 % (GE : 36 %)
Transactions frauduleuses	25 %
Demande de rançon	14 %
Effacement ou altération de données	13 %

Données ou systèmes chiffrés par ransomware	11 % (GE : 17 %)
Défiguration de site	6 %
Désinformation	4 %
Cryptojacking	3 %
Système industriel	1 %

Conséquences business :

- **81 %** des entreprises attaquées subissent un **impact sur le business** ; 19 % aucun impact.
- Détail des impacts :
    - **perturbation de la production** : 28 % ;
    - **perte d'image / impact médiatique** : 26 % ;
    - compromission d'informations ou de savoir-faire : 18 % ;
    - **perte de chiffre d'affaires** : 18 % ;
    - site web indisponible : 17 % ;
    - arrêt de la production : 14 % (GE : 20 %) ;
    - perte financière directe : 14 % ;
    - **déconnexion par des tiers** (mise en quarantaine par les partenaires) : 12 % ;
    - retard de livraison : 8 % ;
    - impact sur les biens et les personnes : 8 % ;
    - sanction par une autorité : 3 % ;
    - contrefaçon : 1 %.

Menace liée au cyberespionnage :

- **40 %** des entreprises l'estiment élevée (10 % « très élevée », 30 % « assez élevée »), contre 37 % à la vague 10.
- 36 % la jugent assez faible, 24 % très faible.
- Évolution perçue :
    - **53 % en augmentation** ;
    - 24 % stable ;
    - moins de 1 % en baisse ;
    - 23 % peu ou pas concernées.
- Différentiel : **+52**.

Exemples de coûts :

- Coût moyen d'une cyberattaque : **5 M$** (Ponemon, 2013).
- Attaque **Target** : **61 M$**.
- Attaque **Sony (2011)** : **2 milliards de $**.
- **91 %** des entreprises ont subi au moins une cyberattaque en 2013.
- Un **DDoS de quelques heures** sur un gros site marchand peut coûter **plusieurs centaines de milliers d'€**, rien qu'en surcoût d'**appels au service client**.

③ **L'individu**

Les particuliers sont une **cible privilégiée**, car ils sont **bien moins protégés** que les entreprises.

Exemples :

- un ver Android qui se propage via les contacts et envoie des **SMS surtaxés** ;
- l'expansion des **cryptolockers** ;
- un **vol massif de données chez Yahoo** ;
- les **botnets**, source majeure de **fraude bancaire** (le FBI les combat).

Cas Ashley Madison (★) :

- **9,7 Go** de données divulgués sur le **darknet**, accessible via **Tor**.
- Contenu : coordonnées géographiques, données bancaires (en partie), transactions des **7 dernières années**, identifiants.
- En revanche, les **mots de passe sont restés chiffrés**, avec une protection jugée **supérieure à la plupart des sites** (Robert Graham, *Wired*).
- → **Leçon : un bon chiffrement des mots de passe ne suffit pas.** Toutes les autres données sensibles ont fuité, avec des conséquences humaines lourdes.

📊 **Secteurs ciblés (Hackmageddon Q2 2022, 1174 événements)**

Secteur	Part
J – Information & Communication	**26,1 %**
O – Administration publique & Défense	**15,5 %**
Multiple	14,3 %
K – Finance & Assurance	**10,1 %**
T – Ménages (particuliers)	4,5 %
Q – Santé	3,3 %
M – Activités scientifiques et techniques	3,2 %
G – Commerce	3,1 %
C – Industrie manufacturière	3,0 %
P – Éducation	2,6 %

---

4. Les méthodes d'attaque (★★ cœur du cours)

Le cours analyse **4 types d'attaques** avec toujours la **même grille** :
Objectifs → Cibles → Moyens → Détection → Qualification → Action → Prévention

① **L'attaque virale**

Critère	Contenu
Objectifs	Renommée / nuisance / vol d'information

Cibles	**Diffusion non maîtrisée** : pas de cible précise, le code se propage partout
Moyens	Logiciel malveillant (virus, troyen…)
Détection	**Signature** du code malveillant, **comportement** anormal (charge CPU, trafic réseau)
Qualification	Criticité des serveurs contaminés et **taux d'infection**
Action	**Éradiquer toutes les instances**, analyser la propagation et le fonctionnement du code

Les familles de malwares :

Type	Fonctionnement
Virus	A besoin d'un **hôte** (fichier, secteur de démarrage, macro)
Cheval de Troie (troyen)	Logiciel **piégé** qui a l'air légitime et ouvre une **backdoor**
Ver	Se propage **sans hôte**, de façon autonome. Ouvre des backdoors ou installe des virus
Rogue	**Faux logiciel de sécurité** (faux antivirus) qui réclame une mise à jour **payante**
Spyware	Espionne : **keylogging**, surveillance du comportement

→ Piège : **un virus a besoin d'un hôte, un ver non.**

② **L'attaque opportuniste de site web**

Critère	Contenu
Objectifs	Vol de données clients ou d'informations / nuisance à l'image
Cibles	Tout site hébergeant des **données monnayables**
Moyens	Défauts de conception, **absence de mise à jour**, vulnérabilité d'une application ou du système
Détection	Surveillance des **journaux (logs)**, en particulier des accès aux données par les applications
Qualification	Criticité et volume des informations exposées
Action	**Isoler le site** (mise hors ligne), puis corriger et mettre à jour
Prévention	**Audits de sécurité**, surveillance

Exemples :

- **Injection SQL (SQLi)** : insérer du code SQL dans un champ de saisie pour manipuler la base de données.
- **Violation de la gestion d'authentification et de session** : vol de cookies, question secrète mal choisie, contournement de la page de login.
- **XSS (Cross-Site Scripting)** : injecter un script malveillant dans une page vue par d'autres utilisateurs.
- **Défacement** de site ou d'URL.

→ Le mot **« opportuniste »** est important : l'attaquant **profite d'une faille existante**, il ne vise pas spécialement cette cible.

③ **Le déni de service (DoS / DDoS)**

Critère	Contenu
Objectifs	Nuisance / **chantage** / **dissimulation de preuves**
Cibles	Tout site visible, généralement à **forte visibilité**
Moyens	**Saturer** les serveurs avec un grand nombre de requêtes, ou avec **très peu** (Slowloris)
Détection	**Pic de charge** réseau ou CPU
Qualification	Débit des requêtes, criticité du site, impact client (appels au service client)
Action	**Confinement le plus en amont possible**, services de **filtrage** des requêtes
Prévention	Procédures de traitement rédigées, surveillance des charges, **offres de filtrage** anti-DDoS

Les variantes :

- **DoS** : toutes les requêtes viennent d'**une seule source**.
- **DDoS** (*Distributed*) : les requêtes viennent de **nombreuses sources**, souvent un botnet. C'est plus dur à bloquer.
- **Exploitation de failles système ou protocolaires** : champs malformés, fragmentation de paquets.
- **Flooding** (inondation) : SYN flood, UDP flood, Chargen DoS.
- Outils et techniques : **LOIC/HOIC**, **Ping of Death**, **Smurf**, **Slowloris**.

Slowloris (★ à savoir expliquer) :

1. Script en Perl écrit par **Robert « RSnake » Hansen**.
2. Il ouvre **beaucoup de connexions** avec le serveur en envoyant des **requêtes HTTP partielles**.
3. Il envoie **périodiquement des en-têtes bidons**, sans jamais terminer la requête.
4. Le serveur garde chaque **connexion TCP ouverte** en attendant la fin de la requête.
5. Toutes les connexions disponibles sont occupées : **le serveur est saturé** avec très peu de trafic.

→ Idée clé : **Slowloris ne sature pas la bande passante, il épuise les connexions.** C'est une attaque « lente » et discrète.

💡 Le DoS peut servir de **diversion** : on sature les logs pour **masquer une autre attaque**.

④ L'attaque ciblée : APT (Advanced Persistent Threat)

Critère	Contenu
Objectifs	**Intrusion discrète** / capacité d'attaque / vol de données / **espionnage**
Cibles	Des entreprises qui présentent un **intérêt précis**
Moyens	Attaque **évoluée**, avec de **lourds moyens** (compétences et matériel)
Détection	Signaux faibles : **binaire modifié**, ralentissements, **espace disque anormal**
Qualification	**Périmètre de la compromission**, informations et équipements accessibles
Action	**Confinement**, **dépôt de plainte**, assistance d'experts (**inforensique**)
Prévention	Surveillance, **patch management**, vigilance, réseau sécurisé selon l'état de l'art

Ce que signifie APT :

- **Advanced** : techniques sophistiquées (0-day, ingénierie sociale).
- **Persistent** : l'attaquant **reste longtemps** dans le système, discrètement.
- **Threat** : une menace **organisée**, souvent étatique ou très structurée.

Exemples de moyens :

- **ingénierie sociale** ;
- **faux employés** ;
- **intrusion experte avec des 0-days** (failles encore inconnues).

Impacts : potentiellement **très lourds**. Il est difficile d'identifier tous les équipements touchés, et souvent il faut **tout reconstruire** : architecture réseau et système, surveillance, gestion de crise.

📊 Vecteurs d'attaque (Hackmageddon, 1084 événements)

Vecteur	Part
Malware	**40,5 %** (439)
Account Takeover (prise de contrôle de compte)	**14,4 %** (156)
Ransomware	**9,7 %** (105)
Remote Code Execution	2,6 %
Extension de navigateur malveillante	1,5 %
DDoS	1,4 %

Élévation de privilèges	1,2 %
Scam	1,2 %
Exploitation de vulnérabilité / injection de script	1,0 % chacune
Unknown	18,8 %

---

5. Résumé des 4 attaques (★★ tableau à connaître par cœur)

Attaque	Principe	Finalités
Virale	L'utilisateur **exécute plus ou moins volontairement** un logiciel malveillant	Vol d'informations, **création d'un botnet**, **rançon**
Opportuniste web	Exploiter un **défaut de conception** ou une **absence de mise à jour**	Vol de données, rançon, **vandalisme**
Déni de service	**Saturer** la cible pour l'empêcher de rendre son service	**Atteinte à l'image**, **masquage d'une attaque antérieure** en saturant les logs
Ciblée (APT)	**Intrusion discrète** avec des moyens avancés : vulnérabilités techniques et **ingénierie sociale**	Vol de données, **interceptions**, utilisation des moyens compromis (serveurs, réseau) à des fins malveillantes

Classement selon le niveau de ciblage et de compétence :

Virale (non ciblée) → Opportuniste (cible de circonstance) → DoS (cible visible) → **APT (cible choisie, expertise maximale)**

---

6. Pour aller plus loin (hors poly, utile pour comprendre)

La triade DIC (ou CIA en anglais) : ce que la sécurité protège.

- **D**isponibilité : le service fonctionne. Attaquée par le **DoS**.
- **I**ntégrité : les données ne sont pas modifiées. Attaquée par l'**injection**, le **défacement**, l'altération.
- **C**onfidentialité : seules les personnes autorisées accèdent à l'information. Attaquée par l'**exfiltration**, l'**espionnage**, les **fuites**.
- On y ajoute souvent la **traçabilité** (preuve) : c'est à cela que servent les **logs**.

Lien avec le cours A1 (veille / intelligence économique) :

- l'**espionnage** correspond au sommet de la pyramide de Fayol (hors cadre légal) ;
- le **vol d'information noire** est une infraction pénale ;

- l'**ingénierie sociale** figurait déjà côté illégal dans la slide p. 24 du cours A1.

Synthèse complète – Sécurité de l'information, p. 15 à 36

(C. Batbedat, UE IERS. Tes notes de cours sont intégrées et complétées avec le poly. Ce qui vient de tes notes et n'est pas dans le poly est signalé 📝.)

1. Les acteurs de la sécurité de l'information (p. 15-16)

Une frontière ténue : le cas du 0-day

- Un **0-day** est une vulnérabilité **encore inconnue** de l'éditeur, donc **sans correctif**.
- Elle se vend **très cher**, à des acheteurs très différents :
    - des **services de renseignement**, qui veulent un moyen de s'introduire sans être repérés ;
    - des **organisations mafieuses ou criminelles**, qui veulent la monnayer ;
    - l'**éditeur concerné**, pour protéger son image, ou ses **concurrents**, pour lui nuire.
- Le spécialiste qui en trouve un doit faire **un choix éthique** : la vendre, la signaler, la publier…
- Les **bug bounty** sont des programmes où une entreprise **paie** les chercheurs qui lui signalent des failles. Les plus prisés concernent toujours la sécurité.

Le « dark side »

Acteur	Spécialité	Niveau
Script kiddies / lamers	Débutants qui utilisent des **outils « clé en main »**	Faible connaissance et peu de maîtrise
Crackers	**Casser les protections** des logiciels (licences, DRM)	Spécialisé
Phreakers	Utilisation frauduleuse des **systèmes téléphoniques**	Spécialisé
Carders	Attaque des **cartes à puce** (SIM, CB)	Spécialisé
Black hat hackers	Pirates experts qui **trouvent les 0-days**, puis les **vendent ou les louent**	**Très élevé**

Le « white side »

Hacker

- Expert, souvent chercheur.
- Le terme **n'est ni péjoratif ni négatif en soi** : il désigne quelqu'un de curieux, qui veut comprendre le fonctionnement des choses en détail.
- Son expertise sert à des actions positives : mieux protéger, analyser un malware.

Expert en sécurité

- ⚠️ **Tous les experts en sécurité ne sont pas des hackers.**

- La **gouvernance** (l'organisation de la sécurité) est primordiale. Elle demande d'autres compétences : organisation, synthèse, persuasion, pédagogie, maîtrise des normes, management.
- 📝 Ta note : une grosse expérience (plus de 10 000 heures), à la fois **technique ET gouvernance**.

RSSI (Responsable de la Sécurité des Systèmes d'Information)

- **Poly** : il porte la responsabilité d'appliquer la **Politique Générale de Sécurité de l'Information** sur son périmètre (une direction, un périmètre technique, une entité). Il **organise, contrôle la mise en œuvre et rend compte** de la sécurité.
- 📝 **Tes notes** complètent ses missions :
  - **organiser** la stratégie ;
  - **évaluer** les risques ;
  - **communiquer** ;
  - **sensibiliser** ;
  - **contrôler** la mise en œuvre ;
  - **assurer le suivi et la veille**.

L'industrie de la sécurité

Famille	Ce qu'ils font	Exemples
Équipementiers	Produisent du **matériel** de sécurité	Firewalls, routeurs, proxys, **WAF**, sondes
Éditeurs de logiciels / solutions	Vendent des **solutions logicielles**	Antivirus, firewalls, **sandbox**, 📝 bastions
Services de conseil	Apportent de l'**expertise**	Expertise technique, **inforensique**, organisation, sensibilisation et formation, communication, **gestion de crise**, **exercices de sécurité**

Quelques définitions :

- **WAF** (*Web Application Firewall*) : un pare-feu spécialisé qui protège les applications web contre les injections SQL, le XSS, etc.
- **Sandbox** : un environnement isolé où l'on exécute un fichier suspect pour observer son comportement sans risque.
- **Bastion** : un point d'accès unique et contrôlé par lequel passent tous les administrateurs pour atteindre les systèmes sensibles. Toutes leurs actions y sont tracées.

---

1 bis. 📝 L'ANSSI et les « visas de sécurité » (tes notes, complétées)

L'ANSSI

- **Agence nationale de la sécurité des systèmes d'information**, créée en **2009**.
- C'est l'**autorité nationale** en matière de cybersécurité.

- Elle est rattachée au **SGDSN** (Secrétariat général de la défense et de la sécurité nationale), lui-même placé sous le **Premier ministre**.
- Son équipe de réponse aux incidents est le **CERT-FR** : c'est lui qui publie les panoramas de la menace cités dans le poly.

Ses missions (tes 7 verbes) :

Verbe	Concrètement
Coordonne	La réponse nationale aux cyberattaques
Délivre	Les **visas de sécurité** (qualifications, certifications)
Anime	L'écosystème cyber (industriels, prestataires, formations)
Prévoit / prévient	Anticipe les menaces et publie des recommandations (guide d'hygiène, etc.)
Défend	Les SI de l'État et des **OIV**, en intervenant en cas d'incident majeur
Conçoit	Des produits et des architectures sécurisés pour l'État
Sensibilise	Le public, les entreprises, les administrations

> **OIV** (Opérateur d'Importance Vitale) : un opérateur dont l'activité est indispensable à la Nation (énergie, eau, santé, transport…). Il est soumis à la LPM (voir le cadre légal, p. 37 et suivantes).

Les visas de sécurité délivrés ou encadrés par l'ANSSI

Un **visa de sécurité** atteste qu'un produit ou un prestataire a été évalué par l'ANSSI.

Qualifications de prestataires : elles garantissent qu'un **prestataire de services** est compétent et de confiance.

Sigle	Signification	Rôle
PASSI	Prestataire d'**Audit** de la Sécurité des SI	Audits, tests d'intrusion
PRIS	Prestataire de **Réponse** aux Incidents de Sécurité	Intervient pendant ou après une attaque (inforensique, remédiation)
PDIS	Prestataire de **Détection** des Incidents de Sécurité	Services de SOC et de supervision

→ Moyen mnémotechnique : les trois lettres du milieu suivent le cycle **Audit** → **Détection** → **Réponse**, c'est-à-dire **avant, pendant, après** l'incident.

Qualification cloud : SecNumCloud

- C'est le **plus haut niveau** de sécurité et de **souveraineté** pour une **offre cloud** en France.

- Elle exige notamment une protection contre les **lois extraterritoriales**, comme le Cloud Act américain (voir 2021 plus bas).

Certification de produits

- **CSPN** (Certification de Sécurité de Premier Niveau) : un produit de sécurité est évalué **en temps limité** par un laboratoire agréé. C'est plus rapide et moins cher que les **Critères Communs**, la certification internationale plus poussée.

Référentiel

- **RGS** (Référentiel Général de Sécurité) : les règles de sécurité imposées aux **autorités administratives**, notamment pour leurs téléservices (authentification, signature électronique, confidentialité…).

---

2. 📝 DORA et NIS2 : la réglementation européenne

	DORA	NIS2
Nature	**Règlement** UE	**Directive** UE (2022/2555)
Conséquence juridique	**Directement applicable**, pas de transposition nécessaire	Doit être **transposée** dans chaque droit national
Secteur	**Financier** (banques, assurances, et leurs prestataires IT)	**Très large** : 18 secteurs essentiels et importants
Objet	Résilience opérationnelle numérique	Élever le niveau de cybersécurité dans l'UE (succède à NIS1)
Date	En vigueur le 16/01/2023, **applicable depuis le 17/01/2025**	Transposition prévue pour le 17/10/2024

→ **Le point clé : un règlement s'applique directement, une directive doit être transposée.** C'est pour cela que DORA s'applique déjà alors que NIS2 « n'est pas encore arrivée » en France.

Où en est NIS2 en France (ta note est juste) :

- Au 11 septembre 2026, aucune loi française de transposition de la directive NIS 2 n'est promulguée. Le texte qui doit la transposer est le projet de loi Résilience, adopté par le Sénat le 12 mars 2025 puis par la commission spéciale de l'Assemblée le 10 septembre 2025. Haxoris
- Ce projet de loi unique transpose trois directives : NIS2, la directive REC sur la résilience des entités critiques, et la directive qui accompagne le règlement DORA pour le secteur financier. Sildaro
- Conséquence du retard : le 8 juillet 2026, la Commission européenne a saisi la Cour de justice de l'UE contre la France, l'Irlande, l'Espagne et les Pays-Bas pour défaut de transposition, en demandant des sanctions financières. STELLISK.
- Pour se préparer malgré tout, l'ANSSI publie depuis le 17 mars 2026 le Référentiel Cyber France (ReCyF), diffusé comme document de travail. STELLISK.

- Ampleur : l'ANSSI estime le nombre d'entités concernées entre 15 000 et 18 000 en France. NIS2 ne vise plus seulement les grands opérateurs, elle descend jusqu'aux PME et ETI. Deefense

  ⚠️ Le panorama 2022 du poly indique une transposition prévue « d'ici septembre 2024 ». Cette date n'a pas été tenue.

---

3. L'état de la menace liée au numérique (panoramas ANSSI / CERT-FR)

Vocabulaire indispensable avant de lire les panoramas

Sigle	Signification
MOA	**Mode Opératoire d'Attaquant** : un « profil » d'attaque attribué à un groupe (ex. un MOA chinois)
RaaS / MaaS	*Ransomware / Malware as a Service* : le rançongiciel ou le malware est **loué** comme un abonnement
C2	Serveur de *Command & Control* : le serveur qui pilote les machines infectées
Infostealer	Malware qui **vole des identifiants**, cookies, mots de passe enregistrés
Courtier en accès initiaux	Criminel qui **revend des accès** à des réseaux déjà compromis
LotL	*Living off the Land* : l'attaquant utilise les **outils légitimes déjà présents** (PowerShell, cmd.exe), ce qui le rend peu détectable
RMM	*Remote Monitoring & Management* : outils de prise en main à distance (AnyDesk, TeamViewer, VNC)
Équipement de bordure	Un équipement exposé à Internet, en périphérie du réseau (VPN, firewall, passerelle)
Supply chain	Attaque **indirecte** qui passe par un fournisseur ou un sous-traitant
Prépositionnement	S'installer discrètement dans un système **pour agir plus tard** (sabotage, espionnage)
Double / triple extorsion	Chiffrer **et** menacer de divulguer les données, **puis** faire pression sur les clients et partenaires de la victime

---

🔴 2025 (Panorama CERT-FR publié en 2026) (★★ le plus important, c'est le plus récent)

Tendances générales

- **Fin 2025**, des attaques coordonnées visent les **infrastructures électriques en Pologne**, ce qui est devenu le quotidien de l'Ukraine. On craint **d'ici 2030** davantage d'**attaques hybrides** en France, c'est-à-dire des cyberattaques avec des **effets physiques concrets**.
- Le niveau de cybermenace est **élevé, n'épargne personne**, et les attaquants sont **de plus en plus difficiles à suivre**.
- **La frontière entre acteurs étatiques et cybercriminels s'érode.** Ils partagent les mêmes moyens.
- Les **revendications** sont parfois **bruyantes mais pas toujours sincères**, parfois **discrètes et inquiétantes** car elles annoncent des attaques futures.
- Les attaquants cherchent de plus en plus à **échapper à la détection et à l'identification**.
- Un **effort continu d'acteurs étatiques russes et chinois** vise les réseaux **diplomatiques** et les **infrastructures critiques** (télécoms, énergie), en vue d'attaques ultérieures.
- Les attaques **purement cybercriminelles par rançongiciel baissent**, mais les **attaques contre les données via la compromission d'environnements Cloud explosent**.

A. Extorsion, espionnage, déstabilisation

Extorsion de fonds :

- Rançongiciels en **double ou triple extorsion**, parfois **sans même chiffrer** les données.
- Cibles : TPE, PME, ETI, collectivités, établissements de santé et d'enseignement.

Acteurs cybercriminels :

- **128 attaques par rançongiciel** traitées :
    - santé : 8 % (en hausse) ;
    - collectivités : 11 % (en baisse) ;
    - enseignement : forte hausse.
- Opération internationale de démantèlement **EndGame**.
- **196 exfiltrations de données** (contre 130 en 2024). Les données servent ensuite à :
    - la **revente** à des courtiers en accès ;
    - l'**extorsion** directe (chantage à la publication) ;
    - l'**hacktivisme** (déstabilisation).
- Seules **80 revendications** ont pu être **confirmées**.
- Recours fréquent aux **infostealers**.

Acteurs étatiques :

- Des **MOA nord-coréens** visent les **cryptoactifs** et utilisent du **RaaS**.
- **Nouveauté** : des MOA **chinois** utilisent eux aussi des rançongiciels. On avait déjà observé plus d'espionnage au second semestre 2024, mais l'usage du rançongiciel par ces acteurs est nouveau.

Renseignement (MOA russes et chinois) :

- Espionnage stratégique contre des **entités gouvernementales et des ONG** (ex. RSF, par un MOA russe).
- **Entités diplomatiques** visées :

    - un cas français (exploitation de vulnérabilités) ;
    - des ambassades à Moscou (attaque **Adversary-in-the-Middle**, puis déploiement de code malveillant) ;
    - l'Asie du Sud-Est (MOA chinois).
- Objectifs : **espionnage** et **prépositionnement stratégique**.

Déstabilisation (sabotage et DoS) :

- Le **sabotage russe contre l'Ukraine** est suivi de près pour **anticiper des attaques contre la France**. Il s'agit de destruction de données via l'exploitation de vulnérabilités.
- **DDoS** d'hacktivistes contre des infrastructures industrielles (énergie renouvelable, via des failles d'authentification). Les DDoS des hacktivistes et des cybercriminels sont nombreux mais souvent **superficiels**.

B. Évolution des capacités des attaquants

Utilisation de services légitimes :

- Déjà pratiquée par les MOA russes et chinois. **Nouveauté : les cybercriminels s'y mettent aussi.**
- Services utilisés :
    - **RMM** (AnyDesk, TeamViewer, VNC) ;
    - **stockage en ligne** (Google, Dropbox) pour déployer des maliciels ;
    - services d'aide au développement.
- Conséquence : **moins de loaders et de botnets**.
- Objectifs : collecte, exfiltration, téléchargement de code, **latéralisation** (se déplacer dans le réseau) et **persistance**.
- ⚠️ L'attaque est **dissimulée derrière un usage légitime**. D'où l'importance de la **supervision sécurité**.

Intelligence artificielle (triple rôle) :

1. **Moyen d'attaque** : génération de faux sites, etc.
2. **Cible** : les chatbots intégrés aux services.
3. **Compromission des données d'entraînement** : un risque lors de l'usage de l'IA en entreprise.

Explosion de l'ingénierie sociale :

- **SIM swapping** : l'attaquant fait transférer le numéro de la victime sur sa propre carte SIM.
- **MFA fatigue** : il bombarde la victime de demandes d'authentification jusqu'à ce qu'elle en accepte une.
- **Usurpation d'identité**.
- **Hameçonnage vocal** : un faux support informatique appelle, fait installer un RMM, puis prend le contrôle de la machine.
- Attaques via **WhatsApp et Signal**.
- **ClickFix** : un **faux captcha** pousse la victime à **taper elle-même** une commande qui télécharge et exécute un maliciel.

Suivi des capacités des attaquants :

- Les outils publics et les mauvaises pratiques **brouillent l'imputation**, c'est-à-dire l'identification de l'attaquant (ex. la faille **Ivanti**).
- **Brouillard technologique et organisationnel** créé par le RaaS et le MaaS : attaques massives, codes qui évoluent, **résilience malgré les démantèlements**, C2 instables.
- Les fuites touchent aussi les attaquants : **les opérateurs de MOA sont eux-mêmes victimes** (compromission de leurs données, rivalités, vengeances internes). Cela aide à **mieux les comprendre**.

C. Ciblages et opportunités d'accès

- **Défaut de sécurisation des cibles** : les audits sont **trop focalisés**, il manque une vision globale, les audits **red team** sont trop parcellaires. → **Il faut des audits larges.**
- **Contexte légal** : certaines lois imposent l'usage d'**applications malveillantes**, y compris à des entreprises étrangères (ex. en Chine, pour l'enregistrement administratif).
- **Contexte événementiel** : en particulier les **élections** (voir **Viginum**, le service français de vigilance contre les ingérences numériques étrangères).
- **Opportunités techniques** (vulnérabilités) et **ciblage des sous-traitants**.

🟠 **2024**

JOP 2024 (Jeux olympiques et paralympiques) : contrairement à ce qui était anticipé, **aucune attaque n'a perturbé leur déroulement**. On a quand même observé :

- des tentatives de **déstabilisation** (pro-russes et pro-palestiniennes) ;
- de l'**espionnage** ;
- des attaques **à but lucratif** ;
- des attaques de **communication**, liées aux guerres en Ukraine et au Proche-Orient, et à l'arrestation de **Pavel Durov** (Telegram).

Faiblesses techniques constatées chez les victimes :

- **Sécurisation** (prévention) : commencer par l'**Active Directory**, la **segmentation interne**, l'**authentification forte avec certificats**, les **sauvegardes on-line ET off-line**.
- **Supervision de sécurité** : la détection.
- **Réaction** : gestion de crise, remédiation, réduction des impacts, poursuites.

Tendances :

- **Exploitation massive des vulnérabilités sur les équipements de bordure**, puis sur les équipements internes. Au départ, des **États** les exploitent discrètement. Ensuite, **tout le monde** les exploite sans retenue, une fois le code d'exploitation publié.
    - Réponse européenne : le **Cyber Resilience Act**, qui impose la *security by design* et l'**obligation de notifier les vulnérabilités à l'ANSSI**.
- **Ciblage de la chaîne d'approvisionnement** :
    - **xz utils** : une porte dérobée dans une bibliothèque qui aurait permis de compromettre Linux ;

    - la compromission d'un fournisseur de plusieurs grandes entreprises françaises.
- **Évolution de l'outillage** :
    - des **réseaux d'anonymisation** (Chine, Russie) ;
    - des attaques **à but capacitaire**, puis de l'exfiltration (ex. Microsoft, HP).
- **États et cybercriminels utilisent les mêmes ressources** : furtivité, efficacité, faible coût (**LotL**). La Chine utilise des rançongiciels pour **neutraliser** une cible ou **couvrir de l'espionnage**.
- **Mercenariat** : des entreprises privées vendent des outils d'attaque à des États (ex. **NSO Group**, Pegasus). La riposte passe par des publications d'études, des améliorations de sécurité et des procès. **Les téléphones sont très visés.**

Finalités :

- **Lucratif** : niveau constant et élevé. Les démantèlements sont efficaces, mais l'activité des **courtiers en accès** continue.
- **Déstabilisation** :
    - **DDoS en hausse**, liés aux JOP ;
    - défacements ;
    - sabotage de PME/TPE avec **exploitation médiatique** ;
    - quelques attaques **destructrices** dans les contextes de guerre.
- **Espionnage en hausse** : gouvernements, diplomatie, recherche, think tanks, et **ciblage du secteur des télécoms** (France, USA…), y compris **satellitaire**.

🟡 2023

Situation :

- La menace **continue d'augmenter**, sur fond de tensions géopolitiques et de grands événements en France.
- **Trois principales menaces** selon l'ANSSI : les attaquants liés à la **Chine**, à la **Russie**, et l'**écosystème cybercriminel**.
- **Espionnage stratégique et industriel**. Sont particulièrement visés :
    - les **domaines stratégiques** : think tanks, instituts de recherche, base industrielle et technologique de défense ;
    - ceux qui **transmettent des données** (opérateurs) ;
    - les **ESN** (entreprises de services numériques). Via une ESN, on atteint tous ses clients.
- **Attaques sur les téléphones professionnels** (logiciels espions).
- **Regain des rançongiciels**, avec une menace importante dans l'**énergie** et la **santé**.
- Des intentions lucratives **parfois difficiles à démontrer**, ce qui laisse penser à de l'**espionnage ou de la déstabilisation déguisés**.
- **Regain de l'hacktivisme pro-russe** (DDoS, fausses informations), aux impacts pour l'instant **limités**.
- **Prépositionnement stratégique** en Europe, en Amérique du Nord et en Asie.

Recommandations :

1. Appliquer les **bonnes pratiques d'administration**.
2. **Maintenir à jour** les systèmes.
3. **Chiffrer les données**.

4. Être **vigilant avant et pendant les JO**.

🟢 2022

Situation :

- Malgré la guerre russo-ukrainienne, **la menace a peu évolué entre 2021 et 2022**. Elle reste **élevée**, surtout pour l'**espionnage**.
- Les tensions économiques, notamment dans l'**énergie**, exigent la vigilance de toutes les organisations.
- La **menace de déstabilisation et de prépositionnement** est jugée **crédible**. Elle prend la forme de **DDoS**, de **divulgations de données orchestrées** accompagnées de revendications, ou de **sabotage**.
- Les **rançongiciels** se maintiennent, avec un **regain fin 2022**.
- À ne pas négliger : le **cryptominage**. C'est plus **furtif**, et cela génère des **fonds importants réinvestis** par les attaquants dans de nouvelles capacités.
- Les **élections de 2022** n'ont pas subi d'attaque d'ampleur. En revanche, la **Coupe du monde de rugby 2023** et les **JO 2024** ont été identifiés comme des **opportunités** pour tous les profils d'attaquants.

Recommandations :

- Une **politique de mises à jour** rigoureuse.
- Le **guide d'hygiène informatique de l'ANSSI**.
- La **sensibilisation** régulière des utilisateurs.
- Des capacités de **détection et de traitement d'incident**.
- **NIS2**, adoptée par le Parlement européen le **10 novembre 2022**. Elle élargit le périmètre de supervision de l'ANSSI, prend en compte la **supply chain**, impose des exigences plus fortes et doit réduire les **attaques indirectes**.

🔵 2021 (★ très détaillé dans le poly, p. 22 à 25)

Une véritable économie criminelle :

- Plus d'**1 milliard d'€ de gains par an**.
- Un **réseau économique structuré** :
  - politique **KYC** (*Know Your Customer* : les criminels vérifient leurs propres clients) ;
  - paiement en **cryptoactifs** ;
  - **DNS fast flux** (changement très rapide d'adresses IP pour ne pas être bloqué) ;
  - absence de journalisation ;
  - publicité des services ;
  - choix de **juridictions conciliantes**.
- **Des spécialisations**, comme dans une vraie filière :
  - code malveillant en location (**RaaS**) ;
  - hébergement « **bulletproof** » (qui ignore les demandes de retrait) ;
  - **accès à des réseaux compromis** ;
  - **botnets** ;

    - envoi de **spam** ;
    - **blanchiment**.
- Résultat : des **chaînes d'attaque « à la carte »**, plus difficiles à détecter, analyser et endiguer.
- Le **point faible** de cette économie : s'attaquer à un service partagé (surtout l'hébergement) **nuit à tous ses clients**. Les entreprises peuvent par exemple **bloquer certains AS** (*Autonomous Systems*, des blocs réseau) après avoir analysé les effets de bord.

Rançongiciels traités par l'ANSSI :

- **192 en 2020 → 203 en 2021.**
- **Les PME/TPE/ETI sont en forte croissance** parmi les victimes :

Victimes	2020	2021
PME/TPE/ETI	34 %	**52 %**
Collectivités	24 %	19 %
Entreprises stratégiques	24 %	10 %
Établissements publics de santé	7 %	7 %

Nouveautés observées :

- Des **menaces associées** : divulgation, DDoS, harcèlement téléphonique, contact direct avec les **clients et partenaires** de la victime.
- Après **Colonial Pipeline** (attaqué par le groupe **Darkside**, ce qui a déclenché un état d'urgence énergétique), les USA ont **élevé les rançongiciels au même niveau d'alerte que le terrorisme**.
- Les moyens des forces de sécurité ont été **multipliés par 10 en 2021**.

Conséquences :

- **Convergence des MOA étatiques et cybercriminels** (ex. tous utilisent **Cobalt Strike**), donc distinction difficile.
- ▼ Moins d'attaques contre les entreprises critiques (sauf par des États).
- ▲ Plus de **moyens** et de **compétences** chez les cybercriminels (ils utilisent des 0-days).
- ▲ **Effet de report** vers les infrastructures moins sécurisées (**IoT, Linux**).
- ▲ **LotL** (PowerShell, cmd.exe) et montée des hacktivistes.

Autres constats :

- **Capacités offensives privées en hausse** : outils clé en main, prestations, **0-day et outils 0-click** (qui infectent sans aucune action de la victime). Conçues à l'origine pour lutter contre le crime et le terrorisme, elles servent désormais à l'**espionnage politique** de journalistes, de défenseurs des droits de l'homme, de hauts responsables et d'entreprises.
- **Sentiment d'impunité**, grâce aux moyens mutualisés, et **entrée facilitée de nouveaux acteurs**.

- **L'espionnage est la première finalité en France** : 14 des 17 opérations de cyberdéfense de l'ANSSI en 2021, dont **9 liées à des MOA chinois**.

Les lois extraterritoriales (★) :

Loi	Pays	Effet
ITAR (*International Traffic in Arms Regulations*)	🇺🇸	Contraintes sur les entreprises utilisant des composants américains (ex. Thales, Dassault / Rafale)
FISA (*Foreign Intelligence Surveillance Act*)	🇺🇸	Surveillance électronique et physique des puissances étrangères. **Tous les pays sont concernés**
Cloud Act	🇺🇸	Toute société américaine doit fournir ses données sur décision d'un juge, **y compris celles de citoyens européens**
Loi sur le renseignement	🇨🇳	Impose aux entreprises et aux citoyens de **soutenir sans faille le renseignement chinois**

→ C'est **exactement pour cela que SecNumCloud existe** : garantir que les données ne sont pas soumises à ces lois.

Autres tendances 2021 :

- **Sabotage d'infrastructures critiques** : eau en Israël, eau potable en Floride, port iranien de Shahid Rajaee, énergie aux USA…
- **Influence et déstabilisation** : fake news et divulgations (ex. campagne **Ghostwriter**).
- **Exploitation de plus en plus massive et rapide** des vulnérabilités dès que le code d'exploitation est publié (Exchange, Fortinet, VMware, Pulse Secure, Citrix, **Log4j**, Drupal…). Les **0-days exploités** ont atteint un record en 2021 (environ 60, selon Google Project Zero).
- **Cloud détourné** : pour cibler les utilisateurs mal protégés, et pour sa puissance de calcul (minage). Les difficultés sont :
  - juridiques (localisation des données) ;
  - une infrastructure mal maîtrisée ;
  - des **jetons SSO** faibles ;
  - des responsabilités floues ;
  - une investigation compliquée.
- **Forte hausse des attaques supply chain**, amplifiées quand elles visent des **ESN**.
- **Fuites massives**, pour 4 raisons : lucratives (rançongiciel), idéologiques ou d'influence, revente, négligence.
- Les **données volées sont réutilisées** pour de nouvelles attaques (supply chain, phishing plus crédible).

---

4. Le bilan de Cybermalveillance.gouv.fr (p. 26-30)

Cybermalveillance.gouv.fr est le **dispositif national d'assistance aux victimes**, de sensibilisation et d'observation de la menace. Son numéro d'assistance est le **17Cyber**.

Chiffres 2025 (★)

- **504 000 demandes d'assistance**, soit **+20 %**.
- Évolution : **28 855 (2018)** → 90 604 → 104 999 → 173 047 → 279 804 → 282 256 → 423 021 → **504 810 (2025)**. C'est **×17 en 7 ans**.
- Répartition des demandes :
  - **93 % particuliers** ;
  - 6 % entreprises et associations ;
  - 1 % collectivités et administrations.
- ⚠️ **Rapportées à la population de chaque catégorie**, les chiffres s'inversent :
  - **7 particuliers sur 1000** ;
  - 3 entreprises sur 1000 ;
  - **141 collectivités sur 1000** 😱.
- → **Proportionnellement, les collectivités sont de très loin les plus touchées.**

Et l'IA ?

- Les cybercriminels l'utilisent pour **optimiser la diffusion** (hameçonnage traduit en dizaines de langues, textes et visuels générés).
- Ils l'utilisent aussi pour **gagner en agilité** (faux sites, kits malveillants).
- **Mais** les campagnes de masse **entièrement pilotées par IA ne sont pas attestées** à ce stade.

Top 3 des menaces par public

Public	1re	2e	3e
Particuliers	**Hameçonnage 32,9 %** (−0,8)	Piratage de compte 11,6 % (−6,5)	Violation de données 8 % (+1,2)
Entreprises / assos	**Piratage de compte 21 %** (+1,4)	Hameçonnage 16 % (−4,7)	**Faux ordre de virement** 13,5 % (+2)
Collectivités	**Piratage de compte 20,1 %** (+4,1)	Hameçonnage 19,2 % (−5,2)	**Rançongiciel** 13,1 % (−5,6)

> Le **faux ordre de virement** regroupe l'usurpation d'un créancier, l'arnaque au président, et le piratage d'une messagerie pour demander un **changement de RIB** ou envoyer une **facture avec un RIB usurpé**.

Violations de données : record pour la 2e année consécutive

Ces fuites ont des **impacts dans la vraie vie** :

- **Fédération française de tir, SI sur les armes, Armureries Lavaux** (2 fois) : des **cambriolages ciblés** pour voler des armes à domicile.
- **DGFiP, ShipMonk** (prestataire de **Trezor**) : des **attaques physiques** contre des personnes détenant des cryptoactifs ou une fortune.
- Le site de suivi **bonjourlafuite.eu.org** (« French Breaches ») recense **561 fuites**.

→ **Leçon : une fuite de données n'est pas « que » numérique.** Elle peut mener à des violences physiques.

Les arnaques détaillées

1. Hameçonnage : la première menace pour tous les publics

- Canaux : SMS, mails, messages privés, pubs, appels, **QR codes**.
- Il peut être une fin en soi, mais il **ouvre souvent la porte** à pire : piratage de compte, fraude, espionnage, prise de contrôle, usurpation d'identité.
- **Thèmes les plus consultés** :
    - amende routière **ANTAI** : 234 356 ;
    - pédopornographie (fausse convocation) : 156 984 ;
    - **livraison de colis** : 149 658 ;
    - faux support technique : 136 500 ;
    - **« Coucou maman / papa »** : 133 438 ;
    - faux RIB : 96 168 ;
    - faux conseiller bancaire : 86 939 ;
    - chantage à la webcam : 66 106 ;
    - faux emploi, fausse confirmation de commande, faux message bancaire, Ameli / carte Vitale, impôts, FOVI.

2. Faux conseiller bancaire / faux support technique

- L'hameçonnage sert d'abord à **cibler** la victime.
- Une page ou un mail affiche une **fausse infection** ou un **problème bancaire**.
- La victime est redirigée vers un numéro surtaxé, se voit facturer une prestation, puis **autorise un accès à distance** à son ordinateur, qui est alors compromis.
- Variante : la **fausse validation de commande**.

3. Piratage de comptes en ligne (forte progression)

- Il profite de l'hameçonnage **et de la réutilisation du même mot de passe** : un compte compromis donne accès à tous les autres.
- Une messagerie ou un réseau social piraté donne à l'attaquant :
    - une **excellente base d'ingénierie sociale** ;
    - des infos sensibles ;
    - la possibilité d'**usurper l'identité** de la victime ;
    - l'accès à ses **contacts** (qui feront confiance aux messages) ;
    - toute sa vie numérique.
- Sur un compte pro, cela peut aller jusqu'à la **compromission du SI de l'entreprise**.

4. Arnaque à la tâche

- Promesse d'un emploi mirobolant et sans effort (noter des produits, rédiger des avis).
- Mécanique :
    1. La victime **achète des lots de tâches**.
    2. Une cagnotte n'est versée que si tout est fait dans les temps.
    3. Les lots deviennent **de plus en plus chers et difficiles**.
    4. La victime est « licenciée » et la cagnotte n'est **jamais payée**.

5. Fraude au virement

1. L'attaquant **pirate une messagerie** et y cherche des commandes récentes.
2. Il envoie un faux mail **au nom de la boutique**, prétextant un défaut de paiement, avec les **vrais détails de la facture**.
3. Le paiement part vers le fraudeur.

6. Sextorsion : +924 %

- L'attaquant crée un contact via des sites de rencontre ou des réseaux sociaux.
- Il obtient des contenus intimes, ou les **vole**, ou les **fabrique par IA** (deepfakes).
- Il fait ensuite **chanter la victime** en menaçant de les publier.
- ⚠️ Ne jamais payer. Il faut signaler (Pharos, 17Cyber) et se faire accompagner.

7. Arnaque au recouvrement / à l'indemnisation (résurgence en 2024)

- L'escroc contacte d'**anciennes victimes d'escroquerie** en leur promettant une indemnisation.
- Il récupère leurs données personnelles.
- Il réclame des **« frais »** pour débloquer l'indemnisation : la victime est arnaquée **une deuxième fois**.

---

5. Détection et réaction (p. 30-36) (★★)

Le temps de détection : le *dwell time*

Définition : le *dwell time* est le **nombre de jours pendant lesquels un attaquant est présent** dans le SI **avant d'être détecté**. On utilise la **médiane**. (Source : rapport **M-Trends** de Google / Mandiant. Le poly écrit « Mendiant ».)

Médiane (jours)	2011	2015	2020	2023	2024	2025
Global	**416**	146	24	10	11	**14**
Détection **externe** (notifié par un tiers)	—	320	73	13	11	**25**
Détection **interne** (par l'entreprise elle-même)	—	56	12	9	10	**9**

Entre 2024 et 2025 :

- **+3 jours au global** ;
- **+14 en externe** ;
- **−1 en interne**.
- Pas de grosse évolution dans l'ensemble.

À retenir :

- On est passé de **plus d'un an à environ 2 semaines** en 15 ans.
- **Quand l'entreprise détecte elle-même, c'est bien plus rapide** qu'une alerte extérieure. D'où l'intérêt d'un SOC.

Note du poly sur l'IA :

- Elle permet de **découvrir plus vite des 0-days** et d'**exploiter plus facilement** les failles connues. Les systèmes de détection d'**indicateurs de compromission** (IoC) doivent donc s'adapter.
- Les patchs contiennent beaucoup plus de corrections qu'avant.
- Des outils permettent de savoir plus vite si l'on est exposé.

Le coût direct d'une gestion de crise

Plus l'incident **dure** et plus il est **grave**, plus il coûte cher :

Type d'incident	Ordre de grandeur
Défacement web	> 10 k€
Intrusion **sans** vol de données personnelles	> 100 k€
Attaque DoS	> 1 M€
Attaque ciblée (APT)	> 10 M€ à 100 M€
Intrusion avec vol de données personnelles	**> 100 M€**, et la plus longue

→ Le vol de **données personnelles** est le pire cas : notifications, CNIL/RGPD, procès, image.

Les outils

Outil	Rôle	À retenir
Anti-malware	**Détecter, isoler, éradiquer** les logiciels malveillants	Installé sur les **terminaux** ou sur des **passerelles réseau**
SIEM	= **SIM** (*Security Information Management*) + **SEM** (*Security Event Management*). Analyse **en temps réel** les logs réseaux, systèmes et applications	3 verbes : **normalisation, agrégation, corrélation**. Il lève des **alertes** et aide l'**inforensique**
IDS / IPS	IDS = **Détecter** les activités contraires aux règles. IPS = les **bloquer**	Versions **N**IDS (réseau), **W**IDS (sans fil), **H**IDS (hôte/serveur). Méthodes d'analyse : **signature, anomalie statistique, déviation protocolaire**
NGFW (*Next-Gen Firewall*)	Firewall avec **Deep Packet Inspection** : il regarde le **contenu** des paquets, pas seulement les en-têtes	Intègre IDS/IPS, analyse applicative, **inspection SSL/TLS**, gestion de bande passante, filtrage web avancé

→ Pièges :

- **IDS = alarme** qui détecte ; **IPS = vigile** qui bloque.
- Un **SIEM** ne bloque rien : il **centralise et corrèle** les journaux.

CERT vs COS/SOC

	CERT (*Computer Emergency Response Team*)	**COS (Centre Opérationnel de Sécurité) = SOC en anglais**
Nature	Groupe d'experts qui **gère les incidents**	Centre de **surveillance** et d'analyse
Missions	① **Centraliser** les demandes d'assistance (enregistrement, qualification, corrélation) ② **Traiter les alertes** (analyse, échange avec d'autres CERT, laboratoires) ③ **Base de données de vulnérabilités** ④ **Prévention** (diffusion d'infos, recommandations) ⑤ **Coordination externe** (FAI, CERT, COS, labos)	① **Analyser les menaces** ② **Identifier les vulnérabilités** ③ **Rechercher et qualifier les attaques** en cours ou possibles ④ Définir les **mesures préventives** ⑤ **Assister** les corrections urgentes ⑥ Proposer un **plan d'action à moyen et long terme**
Posture	Plutôt **réaction** et partage	Plutôt **surveillance continue**

La crise de sécurité de l'information

Processus général : 4 phases, 3 jalons

Analyse ──[*plan d'action défini*]──> **Confinement** ──[*plus contaminable*]──> **Éradication** ──[*fin de crise*]──> **Post-mortem**

Phase	**Actions**
1. Analyse	Comprendre, **qualifier avec les experts**, analyser les impacts : périmètre **contaminé** et **contaminable**. ⚠️ Attention particulière aux **impacts business**
2. Confinement	**Traiter le point d'entrée** (« fermer les portes d'entrée »). **Traiter la méthode de rebond** (cloisonner, débrancher). Plus d'autres actions selon le type de crise
3. Éradication	**Nettoyer** (éradiquer les vecteurs d'attaque résiduels) et **protéger** (réviser les moyens de protection)
4. Post-mortem	**Tirer les enseignements** : « qu'aurait-on pu mieux faire ? ». Améliorer la prévention et la réaction

Ce qui rend une crise cyber spécifique (★)

- Une crise **technique classique** a peu de contraintes de confidentialité et des enjeux surtout business.
- Une crise **de sécurité** aboutit le plus souvent à un **dépôt de plainte et une procédure judiciaire**.
- Il faut donc **préserver la preuve** :
    - **empêcher l'attaquant d'effacer ses traces** ;
    - **ne pas détruire soi-même le caractère probant** des éléments (toucher un système peut altérer la preuve).

- Certaines entreprises ont en plus des **obligations sectorielles**, en plus des obligations générales (données personnelles…).

Mesures de précaution :

1. **Mobilisation large** : en interne jusqu'au **COMEX**, en externe des experts en sécurité et en inforensique.
2. **Procédures strictes** : chaque action sur les systèmes peut **invalider une preuve**.
3. **Respect des obligations légales** : la communication peut être très encadrée, parfois par des entités extérieures.
4. **Forte confidentialité** : un attaquant qui se sent repéré **efface ses traces**, surtout s'il a prévu plusieurs accès.
    - ⚠️ Il y a un **paradoxe** : il faut beaucoup d'intervenants, mais on ne sait pas qui est l'attaquant.
    - Solution : **ne donner à chacun qu'une vision partielle** (« besoin d'en connaître »).
5. **Coordination** avec l'extérieur (FAI, État…).

La cellule de crise typique

Direction Générale : prend les décisions lourdes, qui peuvent remettre en cause toute l'activité.

Au cœur de la cellule :

- **Pilote** : l'**intermédiaire avec la DG**. Il **anime, coordonne, arbitre et décide**.
- **Secrétariat du pilote**.
- **Responsable du livre de bord** : il trace **tous les événements et toutes les décisions** dans un **chronogramme précis**. Ce document sert à l'analyse et peut être **versé au dossier judiciaire**.
- **Communication** : veille médiatique, rédaction des messages clés. La communication doit rester **cohérente**.

Autour de la cellule :

- **Correspondant sécurité** (COS / management sécurité).
- **Astreinte de niveau 4** : les **directions métiers** (SI, ingénieries…), qui servent de points de contact.
- **Internes mobilisables** :
    - **Observateur** : aide le pilote dans sa réflexion stratégique.
    - **Secrétariat renforcé** : transmission des documents, gestion des appels.
    - **Service client** : notification aux particuliers.
    - **Service juridique** : valide les plans d'action et la communication (**CNIL**).

⚠️ **Conflit classique** : les techniciens doivent parfois agir **sans connaître la raison** des actions demandées, et ces actions peuvent être **contraires à leurs objectifs habituels**. Exemple : le support doit normalement **maintenir le service à tout prix**, alors qu'en crise cyber, la première mesure est souvent de l'**isoler**, donc de l'**interrompre**.

L'inforensique (*computer forensics*)

Définition : l'**investigation numérique légale**. C'est l'application de techniques d'investigation numérique **qui respectent les procédures légales**, pour apporter des **preuves numériques** à une institution judiciaire (réquisition, ordonnance, jugement).

Autrement dit, c'est l'ensemble des méthodes pour **collecter, conserver et analyser** des preuves numériques **en vue de les produire en justice**. Le concept est construit sur le modèle de la **médecine légale**.

Après la crise, 3 étapes d'analyse :

Étape	Contenu
1. Bilan des dommages	**Infrastructures** (SI, réseau) : criticité des actifs touchés, volume de données perdues. **Impacts classiques** : financiers, juridiques, image, **temps passé** sur la crise
2. Retour d'expérience (RETEX)	**Processus** : détection, alerte, escalade, déclenchement. **Gestion de crise** : communication, organisation, fluidité, confidentialité, mobilisation des bons acteurs. **Traitement de l'attaque** : analyse technique et business, efficacité du **confinement** et de l'**éradication**
3. Plan d'actions	**Lister et prioriser** les actions (complexité / gain). **Planifier** (calendrier, coûts, ressources). **Lancer les projets** et nommer les **responsables du pilotage et du suivi**

1. Les profils d'attaquants

Terme	Définition
Script kiddie (ou **lamer**)	Utilise des logiciels **faits par d'autres**, sans vraiment les comprendre, pour nuire. Peu de compétences
Cracker	**Casse les protections des logiciels** (le « crack ») pour les utiliser sans licence
Carder	Pirate spécialisé dans les **cartes à puce**, en particulier les cartes bancaires

À relier au cours 1 : contrairement au **hacker**, le script kiddie a l'outil **sans la compétence**.

2. Les métiers de la cybersécurité

- **Expert en cybersécurité** : une grosse expérience (**plus de 10 000 heures**), avec une expertise à la fois **technique** et en **gouvernance**.
- **RSSI** (Responsable de la Sécurité des Systèmes d'Information) : il est le chef d'orchestre de la sécurité. Il :
    - **organise** et définit la stratégie ;
    - **évalue** les risques ;
    - **communique** et **sensibilise** ;
    - **contrôle** la mise en œuvre ;

    - **assure le suivi** et la **veille**.

3. Les acteurs du marché

Acteur	Rôle
Équipementiers	Produisent du **matériel** de cybersécurité. Leur poids **diminue** aujourd'hui
Éditeurs de logiciels	Vendent des **solutions logicielles** : antivirus, pare-feux, bastions
Sociétés de conseil	Apportent de l'**expertise** : technique, organisation, sensibilisation, communication, gestion de crise, exercices de sécurité, **inforensique**

Tu as déjà croisé l'inforensique dans le cours 1 : c'est l'action de réponse à une **APT**.

4. L'ANSSI

ANSSI signifie **Agence nationale de la sécurité des systèmes d'information**. C'est l'autorité française de cybersécurité.

Ses sept missions, sous forme de verbes : elle **coordonne**, **délivre** (des qualifications), **anime**, **prévoit**, **défend**, **conçoit** et **sensibilise**.

5. Ce que délivre l'ANSSI

Qualifications de prestataires :

- **PASSI** : Prestataires d'**Audit** de la Sécurité des SI ;
- **PRIS** : Prestataires de **Réponse** aux Incidents de Sécurité ;
- **PDIS** : Prestataires de **Détection** des Incidents de Sécurité ;
- **SecNumCloud** : le plus haut niveau de **sécurité et de souveraineté** pour une offre de **cloud** en France.

Astuce : les trois prestataires suivent les étapes d'un incident. On **audite** avant (PASSI), on **détecte** pendant (PDIS), on **répond** après (PRIS).

Référentiel :

- **RGS** : Référentiel Général de Sécurité, le cadre de sécurité des **administrations**.

Labels et certifications :

- **CSPN** : Certification de Sécurité de **Premier Niveau**, qui porte sur des **produits**.
- **Label cloud** : ton intitulé est flou, vérifie le nom exact dans le poly.

⚠️ Tu as mis **SecNumCloud** à la fois dans les qualifications et dans les labels. C'est une **qualification**. Vérifie comment ton prof le classe.

6. La réglementation européenne

- **DORA** : un **règlement** européen sur la **résilience opérationnelle numérique** du **secteur financier**. Un règlement s'applique **directement**, sans transposition.

- **NIS2** : une **directive** européenne qui élargit les obligations de cybersécurité à beaucoup plus d'entités. Une directive doit être **transposée** dans le droit national, et selon ton cours, elle **n'est pas encore transposée en France**.

Le piège : **règlement = direct**, **directive = à transposer**. C'est ce qui explique que NIS2 « n'arrive » pas encore en France alors que DORA s'applique déjà.